

1. Zweck

Sicherstellung, dass nur autorisierte Personen auf das Produktionsnetzwerk (OT) zugreifen können. Trennung von IT- (Büro) und OT-Netzwerk (Produktion) nach IEC 62443.

● DEVIATIONS (zugehörig zu SOP-IT-001)

DEV-IT-001 – Externer Dienstleister ohne Anmeldung

Datum: 2024-05-15 | Status: Closed

Beschreibung: Siemens-Techniker remote auf SPS zugegriffen ohne 24h Vorlauf

Ursache: Kein automatisiertes Anmeldesystem

DEV-IT-002 – Standardpasswort auf Abfüllmaschine

Datum: 2024-07-20 | Status: Closed

Beschreibung: "admin/admin" nach 6 Monaten noch aktiv

Ursache: Keine initiale Passwortänderung bei Inbetriebnahme

DEV-IT-003 – Fehlende 2FA bei VPN-Zugang

Datum: 2024-08-10 | Status: Open

Beschreibung: Externer Dienstleister nutzte nur Passwort, 2FA umgangen

Ursache: Dienstleister ignorierte Vorgabe, keine technische Sperre

DEV-IT-004 – Zugriffslog nicht vollständig

Datum: 2024-06-12 | Status: Closed

Beschreibung: 3 Tage Logs fehlen (05.06.-07.06.2024)

Ursache: Backup nicht konfiguriert, Speicher voll

DEV-IT-005 – Operator mit Admin-Rechten

Datum: 2024-04-03 | Status: Closed

Beschreibung: Operator Maier hatte unbeabsichtigt Admin-Zugang auf Fermenter

Ursache: Falsche Rolle im Active Directory

DEV-IT-006 – Dienstleister-Vertraulichkeitserklärung fehlt

Datum: 2024-09-15 | Status: Open

Beschreibung: Externer Netzwerktechniker (Firma NetSecure) ohne Unterschrift tätig

Ursache: Keine zentrale Erfassung, HR versäumt Einholung

DEV-IT-007 – Zugriff außerhalb Arbeitszeit

Datum: 2024-10-01 | Status: In Review

Beschreibung: Dienstleisterzugriff um 22:30 Uhr (nur bis 20:00 erlaubt)

Ursache: Keine zeitliche Sperre im System

DEV-IT-008 – Service-Account ohne Zertifikat

Datum: 2024-03-18 | Status: Closed

Beschreibung: Service-Account auf Chromatographiesystem mit Passwort statt Zertifikat

Ursache: Fehlerhafte Konfiguration bei Inbetriebnahme

DEV-IT-009 – Kein Log bei Read-only-Zugriff

Datum: 2024-11-01 | Status: Open

Beschreibung: SCADA-Read-only-Zugriffe von Produktionsleiter nicht geloggt

Ursache: Konfigurationsfehler im SCADA

DEV-IT-010 - Vier-Augen-Prinzip umgangen
Datum: 2024-02-14 | Status: Closed
Beschreibung: Admin-Zugriff wurde nur von IT, nicht von QP genehmigt
Ursache: Kein Workflow für Admin-Freigabe

● CAPAs (zugehörig zu SOP-IT-001)

CAPA-IT-001 - Automatisiertes Anmeldesystem für Externe
Linked DEV: DEV-IT-001 | Status: Effective | Fällig: 2024-06-30
Aktion: Einführung eines Ticketing-Systems (Jira Service Management) mit 24h Vorlauf-Pflicht
Verantwortlich: IT-Leiter

CAPA-IT-002 - Initiales Passwort-Reset bei Inbetriebnahme
Linked DEV: DEV-IT-002 | Status: Effective | Fällig: 2024-08-01
Aktion: Checkliste für Maschinenabnahme ergänzt um Punkt "Standardpasswort geändert"
Verantwortlich: Produktion

CAPA-IT-003 - 2FA für alle externen VPN-Zugänge
Linked DEV: DEV-IT-003 | Status: In Progress | Fällig: 2024-12-15
Aktion: Upgrade des VPN-Gateways (Fortinet), Hardware-Token für alle Dienstleister, Schulung
Verantwortlich: IT-Sicherheit

CAPA-IT-004 - Zentrale Log-Archivierung mit Alarm
Linked DEV: DEV-IT-004 | Status: Effective | Fällig: 2024-07-15
Aktion: Einführung von Graylog mit 365-Tage-Speicher, täglicher Integritätscheck
Verantwortlich: IT

CAPA-IT-005 - Regelmäßiges Role-Review (monatlich)
Linked DEV: DEV-IT-005 | Status: Effective | Fällig: 2024-05-01
Aktion: Automatischer Abgleich AD mit Soll-Rollen, Abweichungsreport an QA
Verantwortlich: IT + QA

CAPA-IT-006 - Zentrale Vertragsdatenbank für Dienstleister
Linked DEV: DEV-IT-006 | Status: Open | Fällig: 2024-12-31
Aktion: Digitale Erfassung mit Verfallsdatum-Alarm, HR-Integration
Verantwortlich: QA

CAPA-IT-007 - Zeitliche Sperre für externe Zugriffe
Linked DEV: DEV-IT-007 | Status: In Progress | Fällig: 2024-11-30
Aktion: Firewall-Regel: Externe Zugriffe nur 06:00-20:00, Ausnahme nur mit QA-Freigabe
Verantwortlich: IT

CAPA-IT-008 - Zertifikatsbasierte Service-Accounts
Linked DEV: DEV-IT-008 | Status: Effective | Fällig: 2024-04-30
Aktion: Migration aller Service-Accounts von Passwort auf X.509-Zertifikate
Verantwortlich: IT

CAPA-IT-009 - SCADA-Logging für Read-only-Zugriffe
Linked DEV: DEV-IT-009 | Status: In Progress | Fällig: 2024-12-15
Aktion: SCADA-Konfiguration angepasst, jeder Read-only-Zugriff wird geloggt
Verantwortlich: IT + Produktion

CAPA-IT-010 - Vier-Augen-Workflow für Admin-Zugriff
Linked DEV: DEV-IT-010 | Status: Effective | Fällig: 2024-03-01
Aktion: Einführung von ServiceNow-Workflow: Admin-Zugriff benötigt IT + QP-Freigabe

CAPA-IT-010 - Vier-Augen-Workflow für Admin-Zugriff

Linked DEV: DEV-IT-010 | Status: Effective | Fällig: 2024-03-01

Aktion: Einführung von ServiceNow-Workflow: Admin-Zugriff benötigt IT + QP-Freigabe

Verantwortlich: QA + IT

○ AUDIT FINDINGS (zugehörig zu SOP-IT-001)

AUD-IT-001 - EMA Inspektion 2024-03-15

Finding: Externe Zugriffe nicht ausreichend kontrolliert (keine 24h Vorlauf)

Linked CAPA: CAPA-IT-001 | Schweregrad: Major | Ergebnis: Accepted

AUD-IT-002 - Internes Audit Q2 2024-04-20

Finding: Standardpasswort auf Abfüllmaschine (admin/admin)

Linked CAPA: CAPA-IT-002 | Schweregrad: Major | Ergebnis: Accepted

AUD-IT-003 - FDA Inspektion 2024-06-10

Finding: Keine 2FA für Remote-Zugang von Dienstleistern

Linked CAPA: CAPA-IT-003 | Schweregrad: Critical | Ergebnis: Open

AUD-IT-004 - Internes Audit Q3 2024-07-15

Finding: Zugriffslogs lückenhaft (3 Tage fehlen)

Linked CAPA: CAPA-IT-004 | Schweregrad: Major | Ergebnis: Accepted

AUD-IT-005 - Kundenaudit (Großhändler) 2024-05-05

Finding: Unklare Rollenverteilung IT/OT (Operator mit Admin-Rechten)

Linked CAPA: CAPA-IT-005 | Schweregrad: Minor | Ergebnis: Accepted

AUD-IT-006 - Behörde (Regierungspräsidium) 2024-09-20

Finding: Dienstleister ohne Vertraulichkeitserklärung

Linked CAPA: CAPA-IT-006 | Schweregrad: Major | Ergebnis: Open

● DECISIONS (zugehörig zu SOP-IT-001)

DEC-IT-001 - Stilllegung Abfüllmaschine (2024-07-21)

Verknüpfungen: DEV-IT-002, CAPA-IT-002

Entscheidung: Maschine für 2 Tage stillgelegt, Passwort zurückgesetzt, Mitarbeiterschulung

Risiko: Hoch

Begründung: Standardpasswort = GMP-Verstoß, potenzielles Produktrisiko

DEC-IT-002 - Externer Dienstleister gesperrt (2024-08-12)

Verknüpfungen: DEV-IT-003, CAPA-IT-003

Entscheidung: Dienstleister (NetTech GmbH) vorübergehend gesperrt bis 2FA implementiert

Risiko: Mittel

Begründung: Wiederholter Verstoß gegen SOP-IT-001

DEC-IT-003 - Chargenfreigabe trotz Log-Lücke (2024-06-14)

Verknüpfungen: DEV-IT-004, CAPA-IT-004

Entscheidung: Charge #4682 freigegeben, aber mit Auflage: erweiterte Stabilitätsprüfung (6 Monate)

Risiko: Mittel

Begründung: Keine Produktbeeinflussung nachweisbar, aber Dokumentationslücke

DEC-IT-014 - Dienstleisterverträge überarbeiten (2024-09-30)

Verknüpfungen: DEV-IT-006, CAPA-IT-006

Entscheidung: Vertragsstrafe 5.000 € pro Verstoß gegen Zugriffsregeln

Risiko: Niedrig

Begründung: Fehlende Vertraulichkeitserklärung = rechtliches Risiko
